Konzeptpapier: M365 Hardening Script Generator

Arbeitstitel. Lokales Werkzeug für 4sight-IT-Techniker, das aus einer geführten Auswahl sicherheitsrelevanter M365-Einstellungen ein **PowerShell-Skript erzeugt**, mit dem diese Einstellungen gesetzt werden. Das Werkzeug **wendet nichts selbst an** – es erzeugt Skripte.

Stand: Scoping abgeschlossen. Dieses Papier hält die getroffenen Entscheidungen, das Sicherheitsmodell und die Architektur fest und dient als Grundlage für die Detailplanung.

---

1. Zweck & Abgrenzung

- **Nutzer:** ausschließlich 4sight-Techniker – teils ohne tiefes M365-Wissen → Oberfläche **streng geführt**, Standard = sicher.
- **Betrieb: ein Tenant pro Durchlauf**, **lokale** Anwendung (kein Web).
- **Ergebnis:** ein **generiertes, kommentiertes PowerShell-Skript** (plus Begleitskripte, s. u.). Ausführen tut der Techniker bewusst selbst.
- **Andockung:** der Einstellungskatalog folgt **eurer Checkliste** (Nummern, Tiers Pflicht/BP/Optional). Dadurch entsteht der Kreis *prüfen (Assessment) → setzen (Generator) → erneut prüfen*.
- **v1-Umfang: schreibbarer Teil der B-Sektion (Intune)**, einzelne Optionen (keine Pakete).

Nicht-Ziele in v1

Kein automatisches Anwenden, kein Web/Multi-Tenant-Rollout, keine Pakete/Bundles, keine Entra-/Exchange-/Purview-Schreibfunktionen (folgen in späteren Phasen), keine Zuweisung an „Alle".

---

2. Grundprinzipien (Leitplanken)

1. **Nur generieren, nie anwenden.** Das Tool schreibt Skripte, keine Live-Änderungen.
2. **Sicher per Default.** Jede Option ist in ihrer sichersten Form voreingestellt.
3. **Keine Aussperr- und keine Betriebs-Brecher.** Einstellungen, die den Nutzer/Admin aussperren **oder** den Betrieb stören können, sind nicht scharf wählbar (s. Risikomodell).
4. **Mensch behält Kontrolle.** Break-Glass-Konten, scharfes Rollout und das „Scharfschalten" bleiben bewusste, manuelle Schritte – klar im Skript und in der UI vermerkt.

---

3. Sicherheits- und Risikomodell *(Kernstück)*

Jede Einstellung im Katalog trägt eine **Risikoklasse**. Sie steuert, ob und wie sie wählbar ist.

Klasse	Bedeutung	Verhalten in der UI
A – sicher	Weder Aussperr- noch Betriebsgefahr	Normal wählbar
B – betriebs-/sicherheitskritisch	Sperrt niemanden aus, kann aber den Betrieb stören (z. B. Firewall eingehend blockieren, ASR scharf, BitLocker, Network Protection, LSA-Schutz)	Nur im **sicheren Modus** wählbar (Audit/Pilot/unassigned), mit sichtbarem Hinweis
C – aussperr-fähig	Kann Nutzer/Admin aussperren (z. B. CA scharf, Legacy-Auth-Block, Security Defaults, eigene Auth-Methode entfernen)	**In der UI gesperrt/ausgegraut** + Hinweis: „Vorsicht – wenn überhaupt, manuell"

„Sicherer Modus" je Fähigkeit (die konkrete sichere Variante): - **Conditional Access** (spätere Phase): ausschließlich **Report-only** erzeugbar – nie scharf; **Break-Glass-Konten automatisch als Ausschluss** in jeder CA; Scharfschalten ist ein kommentierter manueller Folgeschritt. - **ASR-Regeln / Controlled Folder Access: Audit-Modus** zuerst, nie direkt „Block". - **Alle Intune-Profile (v1):** werden **ohne Zuweisung (unassigned)** erzeugt – der Rollout auf eine Gruppe oder „Alle" ist ein bewusster manueller Schritt des Technikers.

Break-Glass-Handhabung - Der Techniker **trägt die Break-Glass-Konten pro Tenant ein** (autoritativ, gespeichert). - Optionaler Helfer „Kandidaten erkennen": schlägt Konten vor, die den typischen Mustern entsprechen (aus CA ausgeschlossen, Cloud-only + Global Admin, unlizenziert, Namensmuster, selten angemeldet) – der Techniker muss jeden

Vorschlag **bestätigen**. - **Ausführung durch ein Break-Glass-Konto wird verweigert** (Prüfung im generierten Skript und in der App).

---

4. Das erzeugte Skript

Zweistufiger Aufbau (ersetzt das bei Graph unzuverlässige `-WhatIf` als Sicherheitsnetz): 1. **Vorschau (read-only):** liest den Ist-Zustand der betroffenen Objekte und zeigt je Einstellung *Ist* → *Soll*, ohne etwas zu schreiben. 2. **Anwenden:** schreibt die Änderungen erst nach bewusster Freigabe. `-WhatIf` wird zusätzlich gesetzt, wo das Cmdlet es sauber unterstützt.

Begleitend pro Lauf: - **Backup / Ist-Zustand-Export** der betroffenen Objekte (JSON) **vor** Änderungen. - **Revert-Skript**, das den vorigen Zustand wiederherstellt bzw. neu angelegte Objekte entfernt. - **Transkript/Log** des Laufs (für die Kunden-Änderungsdoku).

Weitere Eigenschaften: - **Least-Privilege-Scopes:** das Skript fordert nur die Graph-Scopes an, die die gewählten Einstellungen tatsächlich brauchen. - **Feste Namenskonvention** für erzeugte Objekte (z. B. Präfix `4S-`) und **„aktualisieren statt doppelt anlegen"** – existiert ein Objekt gleichen Namens, wird es aktualisiert. - **Kopf des Skripts:** Voraussetzungen, benötigte Rechte, Sicherheitshinweise, Zeitstempel, Liste der gewählten Einstellungen.

---

5. Architektur

- **Katalog als Daten (JSON).** Jede Einstellung ist ein Datensatz, getrennt von der Logik: `id`, `checklistNr`, `workload`, `titel`, `beschreibung`, `riskClass` **(A/B/C)**, `safeMode` (z. B. audit/unassigned), `graphEndpoint` / `cmdlet`, `parameter` / `payload-template`, `requiredScopes`, `dependsOn`, `tier` (Pflicht/BP/Optional), `warnText`, `readbackQuery` (für die Vorschau), `revertStrategy`. → Dieser Katalog ist das **versionierte Kernstück**, in dem die ganze Sicherheit steckt; er wird gepflegt, wenn Microsoft Endpoints ändert.
- **Erzeugung aus geprüften Vorlagen.** Pro Einstellung ein vetted, parametrisiertes Snippet – kein frei generierter Code. Für Intune: **Settings-Catalog-JSON via Microsoft Graph**.
- **Generator = eigenständig, schlank** (nicht Microsoft365DSC als Motor). Begründung: volle Kontrolle, auditierbare Ausgabe, und die „nur-sichere-Optionen"-Leitplanken lassen sich sauber erzwingen – was mit DSC schwergängig wäre. (DSC bleibt als spätere Option denkbar.)
- **App-Stack (Empfehlung, in Detailplanung zu bestätigen):** lokale **Desktop-App unter Windows** – entweder eine .NET/WPF-Anwendung oder eine PowerShell-+-WPF-GUI. Beide passen zur Admin-Welt und zum „läuft lokal, kein Web". Der Katalog (JSON) und die Snippet-Vorlagen sind stack-unabhängig und damit wiederverwendbar.

---

6. v1-Umfang: schreibbarer Teil der B-Sektion (Intune)

Alle Profile werden in v1 **ohne Zuweisung** erzeugt. Klasse steuert die Wählbarkeit.

Nr.	Einstellung	Klasse	Sichere Form in v1
B-04/05	Windows-Konformitätsrichtlinie (+ Aktionen)	A	unassigned
B-08	Defender AV: Echtzeitschutz	A	unassigned
B-09	Cloud-Schutz + Blockierebene	A	unassigned
B-10	PUA-Schutz = Blockieren	A	unassigned
B-11	Verhaltensüberwachung	A	unassigned
B-13	Scan-/Update-Einstellungen	A	unassigned
B-15	Tamper Protection	A	unassigned
B-27	Windows-Update-Ringe	A	unassigned
B-28	Feature-Update-Ziel	A	unassigned
B-32	App Protection Policies (MAM)	A	unassigned
B-12	Network Protection = Block	**B**	**Audit** + Hinweis, unassigned
B-16	ASR-Regeln	**B**	**Audit** + Hinweis, unassigned

B-17	Controlled Folder Access	**B**	**Audit** + Hinweis, unassigned
B-18/19	Firewall an / eingehend blockieren	**B**	Hinweis „Management-Ausnahmen prüfen", unassigned
B-21	BitLocker (XTS-AES-256)	**B**	Hinweis „Key-Escrow verpflichtend", unassigned
B-24	Lokale Admin-Gruppe steuern	**B**	Hinweis, unassigned
B-25	LSA-Schutz (RunAsPPL)	**B**	Hinweis, unassigned
B-29	Security Baseline (Windows)	**B**	Hinweis „viele Einstellungen", unassigned
B-31	Edge-Baseline	A/B	unassigned

(Feineinstufung je Einstellung wird im Katalog final festgelegt; die B-Klasse erzwingt sichere Form + Hinweis, die A-Klasse ist normal wählbar.)

---

7. Offene Punkte & Roadmap

- **Detailplanung:** finaler App-Stack bestätigen; Katalog-Schema je B-Einstellung ausdefinieren; Namenskonvention/Präfix festlegen; Revert-Strategie je Einstellungstyp.
- **Phase 2:** Entra (CA **nur Report-only** inkl. automatischem Break-Glass-Ausschluss, Auth-Methoden, Authorization Policy, Passwortschutz).
- **Phase 3:** Defender/EOP, Exchange, SharePoint – jeweils nach gleichem Risikomodell.
- **Komfort:** Pakete/Bundles; **Rückschreiben in die v1.2-Checkliste** nach dem Setzen (Kreis schließen); später ggf. MSP-/Multi-Tenant-Betrieb.

---

8. Zusammenfassung der getroffenen Entscheidungen

Nur generieren · 1 Tenant · lokal · Techniker-only, streng geführt · Start Intune/B-Sektion · einzelne Optionen · an Checkliste angedockt · Zuweisung unassigned · Rollback/Backup + Revert · Aussperren **und** Betrieb-stören gleich behandelt (Klasse B gesperrt-auf-sicher, Klasse C ausgegraut) · Break-Glass vom Techniker eingetragen (optionaler Erkennungs-Helfer) · Ausführung durch Break-Glass verweigert · Least Privilege · feste Namenskonvention · aktualisieren statt doppelt anlegen · eigener schlanker Generator (kein DSC) · Katalog als Daten.